Analyzing Authentication Protocols & Recommending Implementation Methods for E-Commerce Website Security

Prepared by: Alister A. Rodrigues, Security Analyst, Obsidian SecureTech Solutions

Client Context: Meridian Commerce — Startup E-Commerce Platform

Date: October 2024

Executive Summary

This paper provides a detailed analysis of three authentication protocols viz. Kerberos, New Technology LAN Manager (NTLM), and Lightweight Directory Access Protocol (LDAP) to provide information focusing on their strengths, limitations, and applicability within an e-commerce platform. Each authentication protocol is evaluated for its effectiveness in securing user and employee access, ensuring compliance with industry standards, and supporting efficient management of identity and access controls in a startup resource limited e-commerce environment.

The analysis evaluates each protocol's capability to protect sensitive customer and organizational data, maintain operational continuity and availability, and ensure scalability as the business grows. Additionally, the paper identifies potential security vulnerabilities and limitations for each method and provides recommendations for mitigating these risks.

Based on the findings and observations from the comparative analysis of the protocols, suitable methods, and authentication protocols are recommended for secure and effective integration into the business' website to support current operational needs and future growth of the startup.

Kerberos Authentication Protocol

Introduction to Kerberos

Kerberos is a network security protocol that uses symmetric key cryptography for the verification of users and systems on a network. It fundamentally consists of a trusted Key Distribution Center (KDC) that facilitates secure authentication between users and services using an Authentication Server (AS), Ticket Granting Server (TGS) and symmetric key system.

It provides secure authentication in distributed systems where multiple users need to access services inside the network without the need to transmit passwords over the network for access to every service requested. Its principles are mutual authentication where it verifies both the user and the server, time-based expiry of tickets which ensures that tickets are expired after a short duration, symmetric key cryptography for securely transferring tickets between user and server.

Kerberos Work Process

Key Components Involved

Client. The user's device which initiates authentication.

Authentication Server (AS). A part of the Key Distribution Center that verifies user credentials and issues the Ticket Granting Ticket (TGT).

Ticket Granting Server (TGS). A part of the Key Distribution Center that issues service specific tickets based on the TGT.

Service Server. The service (e.g., file server) that the user wants to access which validates the service ticket.

Session Keys. Symmetric keys used to encrypt communication between the client, KDC, and service ensuring secure transmission of tickets.

User Login & Authentication Request

A user on his device (Client) enters their credentials (e.g. password and username). The client device on its side hashes the password and sends an authentication request to the Authentication Server (AS) along with the username, the user's password itself is not transmitted.

Authentication & Ticket Granting Ticket (TGT) Issuance

The Authentication Server verifies the users password hash against its database which contains all users credentials. If the credentials are legit the Authentication Server then creates a Ticket Granting Ticket which contains the users ID, a timestamp indicating when it was issued, expiration stamp for indicating when it's supposed to be expired and a session key.

The Ticket Granting Ticket is then encrypted using Key Distribution Centers secret key and the session key is encrypted using the user's password hash by the Authentication server before sending it back to the client.

Client Decrypts the Session Key

The client decrypts the session key using the hash of the user's password from initial login. The Ticket Granting Ticket remains encrypted.

Ticket Granting Service Request

When the client wants to access a service (e.g. file server or database), it sends a Service Request to the Ticket Granting Server (TGS). This Service Request contains Ticket Granting Ticket which proves that the client has already been authenticated, the ID of the service that the client wants to access, an authenticator containing client ID and timestamp encrypted with the session key received earlier.

Issuing Service Ticket

The Ticket Granting Server verifies the Ticket Granting Ticket by decrypting it using its

own secret key and checks the timestamp on it for validity. If the ticket is valid it generates a Service Ticket for the requested service. This Ticket includes the clients ID, a new session key for client-service communication and the service's ID and timestamp.

The Ticket Granting Server then encrypts the Service Ticket with the service's secret key, it also encrypts the new session key with the old session key before sending it to the client.

Accessing the Service

The client sends the Service Ticket to the Service Server along with an authenticator containing the client's ID and timestamp which is encrypted using the new session key.

The Service Server decrypts the Service Ticket using its own secret key and decrypts the client's authenticator using the new session key to ensure that the service request is recent and legitimate before allowing access.

If mutual authentication is enabled the Service Server sends back a response to the client encrypted with the session key proving its identity to the client.

Kerberos Real-World Applications & Implementation in E-Commerce Environment

Kerberos in Enterprise Networks

Kerberos is the default authentication protocol in Microsoft's Active Directory environments and even in Linux and Unix systems ensuring secure authentication across users, devices and services for remote login e.g. SSH and Network File Systems (Covic, 2023).

Single Sign-On

Large organizations make use of Kerberos' single sign-on feature for their internal networks and intranet services which allows users to login once and gain access to multiple services like email, database, internal applications without re-entering credentials improving usability and security seamlessly with a single login (Macvittie, n.d.).

Kerberos in Cloud & Distributed Systems

Kerberos is used in distributed computing systems like Apache Hadoop for secure authentication between nodes and users (*Apache Hadoop 3.3.6 – Hadoop in Secure Mode*, n.d.). Even in some databases and web servers like PostgreSQL and Apache HTTP servers for user access controls and secure data transmissions (*Authentication Methods*, 2013).

Kerberos in E-Commerce Environment

Kerberos is implemented to secure the authentication process for users, employees and third party services in an e-commerce website with integrated services like inventory, payment gateways and customer support.

User Authentication & Single Sign-On. The customer only needs to provide their credentials once before being authenticated via single sign-on and being issued with a Ticket Granting Ticket**.** With the use of the TGT the customer can access various parts of the website (e.g. account information, purchase history, cart) without being re-authenticated.

Employee & Access Control. Employees login with their credentials and after being authenticated they can access services which are not available to general customers (e.g. order management, inventory tracking, customer relationship management tools and databases where user data is stored securely).

Kerberos allows integration with VPNs for secure remote access for employees working remotely wanting to access back-end services of the website.

Securing Payment Gateway. Kerberos is used to authenticate communication between e-commerce platforms and the payment gateway ensuring that sensitive transactions are protected by using service tickets and secret keys which the payment gateway validates to ensure only legitimate services can process payments.

Strengths & Advantages of Kerberos

Kerberos provides enhanced security using its principles and features viz. Eliminating the need to transmit passwords in plaintext over the network instead making use of encrypted tickets, mutual authentication where both the client and the server verify each other's identity ensuring that the users are not tricked by fake services and vice versa, ticket expiration and timestamps ensuring previous tickets cannot access services maliciously, single sign-on ensuring that clients and employees do not need to re-enter credentials every time they access different services.

Single sign-on for employees will save time and increase productivity by reducing the administrative overhead associated with multiple logins. As Kerberos uses symmetric key encryption it is faster and less resource intensive compared to the asymmetric key encryption, these efficiencies are important for start-ups with limited bandwidth and resources (McKeown, 2023).

As Kerberos is widely supported across operating systems and platforms making it lightweight as it is built into most systems already, it is also cost efficient for a start-up to integrate it into their environment without needing to invest heavily in other solutions (Covic, 2023). Start-ups leveraging cloud services can integrate kerberos as it enables simple integration across cloud environments due to its widely adopted usage and it supports secure access across distributed systems like databases, file services and web servers (*Apache Hadoop 3.3.6 – Hadoop in Secure Mode*, n.d.), (*Authentication Methods*, 2013).

Weakness & Common Attacks on Kerberos

As Kerberos relies on Key Distribution Center (KDC) ultimately that makes it a single point of failure for the system, attackers can overwhelm the KDC with traffic via DoS attacks rendering it unable to process legitimate authentication requests from employees and users alike,

a compromise to KDC or KDC outage could cause downtime affecting customer logins, transactions process and backend operations which will lead to loss of sales and customer trust causing reputational damage to the e-commerce (Kressin, 2024).

Kerberos makes use of timestamp tickets to prevent any potential replay attacks but if an attacker intercepts a ticket while it is still valid i.e before its expiry, the attacker can then reuse it to impersonate a legitimate user/employee, same would be the case if an attacker gains access to the session key, they could decrypt the tickets by exploiting cryptographic weaknesses in the system to impersonate the user or the services to gain unauthorized access to user accounts and internal services (e.g. admin privileges, payment gateways) which could lead to leak of sensitive data, fraudulent transactions and disruption of services.

Kerberos relies on user passwords which makes it susceptible to brute-force and dictionary attacks if users/employees create weak passwords, the attackers could guess or crack these passwords using brute-forcing tools enabling them unauthorized access to user/employee accounts leading to breach of sensitive customer data and access to administrative systems (Garman, 2003).

Kerberos requires accurate time synchronization between client, services and the KDC, if the clock synchronization is off then valid tickets could be rejected and users may be unable to authenticate and access their accounts or make purchases which could lead to customer frustration and disruptions in service (*Why Does Kerberos Care What Time It Is? - IS&T Contributions - Hermes*, n.d.).

As Kerberos is a single-factor authentication system relying on passwords and not designed inherently for Multi-Factor Authentication (MFA) unless configured to support MFA, the e-commerce platform will be vulnerable to attacks relying on stolen and weak passwords.

Mitigating Risks in Kerberos for an E-Commerce Platform

An e-commerce platform can mitigate risks while deploying kerberos by, implementing MFA (e.g. OTPs, biometrics) for users and employees to enable stronger authentication beyond just passwords, setting up multiple KDCs to prevent the system from a single point of failure, enforcing strong password policies and regularly requiring users and employees changing their passwords to minimize brute-force attack threats, making use of a reliable time synchronization service such as Network Time Protocol (NTP) to keep client and server clocks synchronized, using strong encryption algorithms for tickets and key encryption and using a reliable Cryptographically Secure Pseudorandom Number Generator (CSPRNG) for randomization and uniqueness for encryption algorithms, regularly performing security audits to identify and fix the vulnerabilities, monitoring and logging the authentication activity and setting up alerts for suspicious activity (e.g. failed login attempts, unusual ticket requests).

New Technology Lan Manager (NTLM)

Introduction to New Technology Lan Manager (NTLM)

NTLM is a legacy authentication protocol developed by Microsoft for providing secure authentication between clients and servers in Windows environments. Although NTLM can be used in Linux/Unix environments too it requires additional configuration (Mahdi Mallaki, 2023). It was developed as a fallback option for when Kerberos was unavailable or unsupported (Palko, 2023).

NTLMs main purpose is to authenticate and allow users to prove their identity to the servers or services without requiring to send passwords in plaintext over the networks, securing authentication while still protecting credentials.

NTLMs main principles are backward compatibility for when Kerberos cannot be

implemented, hash based authentication and three-part authentication process where the client and server negotiate on session parameters and agree to use NTLM for authentication, challenge process where the server sends the client a random nonce, and response process where the client combines the nonce with the hashed password and returns it to the server for verification providing secure and confidential transmission over the network.

The latest version of NTLM is NTLMv2 that has been updated by Microsoft for better security, it also includes a session security feature called NTLM2 that can be enabled for mutual authentication.

NTLMv2 Work Process

Key Components Involved

Client. This is the user device trying to access a service on a server.

Server. It is the system that authenticates the client and grants access.

Domain Controller. It is where the user credentials are stored for authenticating. The server communicates with the domain controller for authentication

Negotiation Phase

The client initiates a connection with the server by sending an authentication request for NTLMv2, this request includes the username, password after hashing and domain name.

The server responds letting the client know that it supports NTLMv2 authentication protocol and requests the client to proceed by sending a NEGOTIATE_MESSAGE.

Challenge Phase

The server sends a CHALLENGE_MESSAGE to the client containing a nonce of variable size depending on what the user has requested (e.g. server nonce, timestamp, username, etc), this nonce is unique for each session.

Response Phase

The users password, username and domain name is hashed using HMAC-MD5, a hashing algorithm used in NTLMv2 to generate a NTLMv2 hash. The client then uses this NTLMv2 hash to encrypt the challenge nonce received from the server generating a NTLMv2 Response.

The client then sends this NTLMv2 response back to the server as the AUTHENTICATE_MESSAGE. This helps to prove to the server that the client knows the user's password without sending the password itself.

The server knows the expected hash of the user's password as it is stored in its database (domain controller). The server uses the same method as the client to then combine the user's credentials hash with the challenge nonce to generate the expected NTLMv2 Response.

The server compares the client's NTLMv2 Response with the one it generated and if they match then the client is authenticated successfully.

Session Security

NTLMv2 extends its support for session security features for session integrity and confidentiality, both the client and the server can generate a session key after the authentication process is completed which will be used to sign and verify the integrity of the messages exchanged for the duration of the session. It can also encrypt the messages using the session key to ensure confidentiality of the data (*[MS-NLMP]: Session Security Details*, 2024).

NTLMv2 Real-World Applications & Implementation in E-Commerce Environment

Legacy Systems & Fallback Option

Old Windows systems and applications still rely on NTLM for authentication as they do not support Kerberos and although in some networks where Kerberos is used as a primary authentication method, NTLM serves as a fallback option for when Kerberos fails (e.g. during

network issues, compromise to Kerberos system) (Mora, 2024).

Workgroup Networks

In workgroup networks where no centralized domain controller is configured, NTLM is used as Kerberos requires a domain based setup for (e.g. Active Directory) to ensure strong security although it can be used without an active directory but would not be as secure because it would skip over the initial user credential authentication process. (Drown, 2021).

NTLMv2 in E-Commerce Environment

E-commerce platforms that rely on legacy systems for their internal processes that are hosted on Windows servers that support NTLMv2 can be used to secure access to these systems such as a system that tracks warehouse inventory, employees logging into legacy internal systems can be authenticated using their Windows credentials and it can be activated alongside Active Directory for managing user credentials which can handle NTLMv2 Responses when Kerberos is unsupported with a legacy application.

Configure VPN (Deland-Han, 2024) and Remote Desktop Protocol to use NTLMv2 authentication for remote logins by employees by ensuring that the client and server are both set up use NTLMv2 and configure the policy on the servers to accept NTLMv2 only responses otherwise the authentication will fail (Gates, 2024). E.g. An administrator can login remotely to view or manage the e-commerce financial reports via a VPN connection and get authenticated using NTLMv2.

For different departments in an e-commerce environment to share files and data across Windows file server, NTLMv2 can secure these internal file sharing systems using Server Message Block (SMB) or Common Internet File System (CIFS) protocols, session security can be enabled to ensure that the data transferred is encrypted and integrity checked.

Strengths & Advantages of NTLMv2

As NTLMv2 is natively built into Windows systems there are no additional costs for licenses or third party tools, it also does not require complex setup compared to other authentication protocols making it suitable for startups using Windows servers and workstations providing them with a no cost solution for secure authentication.

NTLMv2 provides better security than its predecessor NTLMv1 by making use of HMAC-MD5, a stronger hashing algorithm compared to MD4, making it more resistant to brute-force attacks (*NTLM*, 2023). Its principle of three part authentication (negotiate-challenge-response) ensures that the password itself is not sent over the network hence reducing the risk of password interception during transmission.

NTLMv2 session security feature provides the ability to encrypt the communication between the client and server ensuring integrity and confidentiality over the network.

Startups using legacy Windows systems due to budget constraints can make use NTLMv2 for securing authentication allows the startups to maximize their investments to other departments and when modern authentication protocols are not available due to failure or compromise in networks, NTLMv2 can be used as a secure fallback option without needing to compromise on security.

NTLMv2 can be integrated with Active Directory to manage user authentication providing the startups with centralized identity management without complex infrastructure.

Weakness & Common Attacks on NTLMv2

NTLMv2 is vulnerable to Pass-the-Hash attacks where the attackers steal hashed credentials from a compromised system, these hashes can be reused to authenticate as that user without requiring the original password. If an attacker obtains the hash of an administrator

account they can then gain unauthorized access to sensitive systems such as customer databases, financial reports and inventory systems (Lenaerts-Bergmans, 2024).

NTLMv2 relies on single factor authentication and provides no support for multi factor authentication, making it vulnerable to phishing attacks where attackers trick the users into providing their passwords leading to unauthorized access (Vaideeswaran, 2023).

NTLMv2 is not as scalable as other methods in large networks, an e-commerce platform that is growing with many users can lead to bottleneck in performance with legacy systems using NTLMv2. As an e-commerce platform integrates more third-party services (e.g. logistics, payment gateways) relying on NTLMv2 could become resource-intensive in cross domain authentication tasks leading to slower authentication and degraded performance (Xcitium, n.d.).

NTLMv2 while providing session security, its encryption capabilities are not as strong compared to others like Kerberos and LDAPS as it uses DES for encryption. For an e-commerce platform dealing with sensitive data (e.g. payment transaction, customer data) it may not prove to be sufficient to meet with the compliance standards such as PCI DSS (*Payment Card Industry Data Security Standard Requirements and Testing Procedures Version 4.0.1*, 2024), GDPR (GDPR, 2016), leading to penalties and breaches in data protection.

Mitigating Risks in NTLMv2 for an E-Commerce Platform

Enable Windows Defender Credential Guard which will isolate the NTLMv2 hashes in a secure storage preventing attackers from dumping and reusing them in pass-in-the-hash attacks. Use network segmentation and firewall rules to limit access of compromised machines in the network from accessing servers and their services (paolomatarazzo, 2024).

Enforce strong password policies (e.g. minimum length, upper/lowercase letters, numericals, etc) making them difficult to crack using brute-force. Implement policies for regular

password changes to prevent stolen credentials from being reused by attackers. Ensure users and employees do not use the same passwords for multiple systems ensuring reduced risk if a single system is compromised.

Enable extended security session providing encryption and integrity checks for authenticated sessions preventing eavesdropping and mitigating the risk of man-in-the-middle attacks ensuring confidentiality. Disable weaker NTLMv1 and LM protocols through group policy and only use NTLMv2 avoiding use of weaker hashing algorithms.

Enable the systems logging and auditing feature for NTLMv2 authentication attempts, logging both failed and successful attempts. Review and audit these logs regularly to detect suspicious activity and failed login attempts indicating attempted attacks. Enable Security Information and Event Management (SIEM) to monitor login and flag anomalies as an automated process detecting early signs of compromise and brute-force attempts.

Lightweight Directory Access Protocol (LDAP)

Introduction to Lightweight Directory Access Protocol (LDAP)

Lightweight Directory Access Protocol (LDAP) was created by Tim Howes of University of Michigan and his colleagues as an alternative to resource intensive X.500 directory protocols, like Directory Access Protocol (DAP) with the aim to be lightweight and produce low overheads while accessing and managing directory services over a network (Bhargava, 2021).

LDAP was designed with the following principles in mind to store and manage data in a centralized directory using a hierarchical structure, authenticate users through credentials stored in the directory and enable access to the directory services to search or modify information (*What Is Lightweight Directory Access Protocol (LDAP) Authentication?*, 2022). It was designed to be vendor neutral and platform independent, meaning it supports working across many

operating systems such as Microsoft Windows, Linux/Unix systems (*WorkOS*, 2024).

The latest version released is LDAPv3 in 1997 which added several features to LDAP extending support to Simple Authentication and Security Layer (SASL) allowing more secure authentication over LDAP by making use of challenge-response based authentication, also supporting new operations through the defined "extended" operation e.g. StartTLS which encrypts communication between a client and LDAP server (*LDAP V3*, n.d.).

A more secure extension for the standard LDAP is LDAPS (Lightweight Directory Access Protocol over SSL) which uses port 636, it uses TLS to encrypt all LDAP packets (e.g. attributes, credentials) by default, enabling a secure connection between client and server providing server authentication and data integrity compared to LDAP which uses port 389 and TCP as the default transmission protocol and is vulnerable during the initial connection phase before using the extended operation StartTLS (Authors, 2022).

Lightweight Directory Access Protocol over SSL(LDAPS) Work Process

Key Components Involved

Client. A user trying to authenticate through a device or web application to request services.

LDAP Server. A server that stores directory data and performs authentication.

TLS Certificate. Issued by a trusted Certificate Authority (CA) and used by the server to prove its legitimacy and to encrypt the communication.

Distinguished Name(DN). A unique identifier for a user in the LDAP directory.

Session Keys. Symmetric keys generated after the TLS handshake to encrypt communication between the client and server.

Bind Request. A LDAP operation used to authenticate the user using their Distinguished

Name and password.

Bind Response. Server's response indicating whether authentication was successful or failed.

Establishing A Secure Connection

Before the authentication process, the client and the LDAP server need to establish a secure connection using TLS handshake.

Client Hello. The client initiates the process by sending a “Client Hello” message to the server. This message includes the client’s supported TLS version, cipher suites supported by the client for encryption and a random nonce to use in the encryption key generation process.

Server Hello. The LDAP server responds with a “Server Hello” message containing the TLS version, cipher suites selected from the client’s list, a random nonce and the server’s TLS certificate containing the server’s public key.

The client then validates the server’s certificate by checking the signature of the Certificate Authority, validity of the certificate and the domain name. If the certificate is valid, the client proceeds otherwise the connection is terminated.

The client then generates a pre-master secret, a randomly generated number and encrypts it with the server’s public key and sends it to the server which then uses its private key for decryption.

Both the client and the server use the pre-master secret number along with the nonce exchanged earlier to generate the session keys. These keys will be used for symmetric encryption of further communication.

The client then sends a “Finished” message encrypted using the session key, signaling the completion of the handshake from the client’s side. The server too sends a “Finished” message

encrypted with the session key, signaling the completion of the handshake from the server's side.

LDAP Bind Request for Authentication

The common method of authentication in LDAPS is using a simple bind mechanism, this includes the client sending an authentication request to the LDAP server, this is known as bind operation. This request includes the user's Distinguished Name(DN) and user's password encrypted within the TLS tunnel.

The LDAP server after receiving the bind request attempts to authenticate the user by checking the user's DN and matching it with the DN stored in the directory, comparing the password with the hashed password stored in the directory. If the password matches the user is authenticated, if it does not match or the DN is incorrect then the authentication is failed.

LDAP Server Bind Response

After validating the user's credentials, the LDAP server sends an LDAP bind response to the client.

If the credentials are correct, the server responds with a bind response "Success" message, allowing the client to proceed with LDAP operations and accessing directory resources.

If the credentials are incorrect or if the user is not authorized to initiate bind operation then the server responds with a bind response "Failure" message.

LDAP Operations and Session Termination

Once authentication is successful, the user can continue to perform LDAP operations such as Search operation to retrieve entries that match a set of given criteria, Compare operation to determine if a specified entry has a particular attribute value, Add operation to create new entry in the directory, Delete operation to remove an entry from the directory, Modify operation to alter and change the content of an entry in the directory, Modify DN operation to change the

DN of an entry in the directory, Abandon operation to stop the processing of a previously requested operation.

After the client is finished with its operations and wishes to end the connection, the client sends an unbind request to the LDAP server requesting to terminate the session. The server then acknowledges the unbind operation request and closes the connection, securely terminating the session.

LDAPS Real-World Applications & Implementation in E-Commerce Environment

LDAPS can be used with directory services such as Microsoft's Active Directory or OpenLDAP by an organization to authenticate users. Active Directory allows for centralized management of user credentials and access permission in an organization ensuring secure authentication and communication. Organizations can use LDAPS with Single Sign-on(SSO) systems to allow users to login once and access multiple services and applications without re-entering credentials (*Single Sign-on (SSO) with LDAP | Harness Developer Hub*, 2014).

LDAPS can be used with Microsoft Exchange and other email systems (e.g. Gmail) for secure authentication and for managing distribution groups, user roles and address books. Websites (e.g. GoDaddy hosted) and cloud based tools (e.g. Microsoft Entra ID, AWS AD Connector) also make use of LDAP to authenticate users against directory services and to move an organization's LDAP resources between directory and the cloud securely. Devices such as routers, switches and network printers make use of LDAP to centrally manage authentication and access control (Instasafe, 2024).

LDAPS in E-Commerce Environment

Customers can login to the e-commerce website to manage their profiles, order history and make purchases. The customer account credentials are stored in an LDAP directory, the

e-commerce uses the LDAPS to securely authenticate them. The website sends the credentials to the LDAP server over a secure TLS connection, where the LDAP server verifies the credentials returning a success or a failure response, permitting the customers access to their accounts for further interactions.

Employees, administrators and customer service agents requiring access to backend systems (e.g. inventory, order management, customer support tool, payment systems) are also authenticated using LDAPS, allowing access control and authentication by storing the credentials and roles into the LDAP directory. The LDAP server checks the user's role and group in the directory to enforce role-based access control (RBAC) (*Using LDAP to Authenticate and Perform RBAC of Management Services*, 2024).

Single Sign-on systems for employees and customers are integrated to allow access to multiple services inside the website or backend without requiring to login repeatedly. Once authenticated the users and employees are then issued with a session ticket that can be used across integrated applications.

Strengths & Advantages of LDAPS

LDAPS encrypts all communications including user credentials and directory information using TLS connection by default ensuring information is not transmitted in plaintext protecting them from relay and man-in-the-middle attacks. Using TLS certificates also provides server authentication which reduces the risk of server impersonation and protects the users from communicating with a malicious server. LDAPS also helps with compliance regulations for security standards such as GDPR (*GDPR Compliance Guide for Active Directory*, 2024), PCI DSS (*Document Library*, 2024) and NIST (Rose et al., 2019) .

LDAPS allows for a centralized user authentication and access controls, simplifying the

process of managing account, roles and permissions for the administrators of a small startup as it provides a unified system across the organization (Gates, 2024b).

LDAPS is efficient and can be scaled accordingly as an organization expands due to its hierarchical structure enabling efficient organization and retrieval of information simplifying the management of large datasets (Jayaraman, 2023), it supports replication which means data can be synchronized across multiple servers enhancing data availability and load distribution and balancing (Metzler, 2020), LDAPS implementations utilize caching mechanisms by default or can be enabled during configuration allowing for faster responses and reduced server load by storing frequently accessed data (*Atlassian Documentation*, 2021), LDAPS can also be distributedly deployed across a network allowing organizations to scale efficiently by adding more servers as load increases (Gillis, n.d.), all these capabilities make LDAPS a recommended authentication protocol for a startup.

LDAPS have open source directory servers (e.g. OpenLDAP) that can be used without the need for expensive licensing fees reducing the costs for a startup to implement authentication, using a centralized LDAP system reduces the overhead for maintenance across various systems saving time and administrative costs (Herrmann, 2015), as LDAPS is a lightweight protocol, it can handle multiple authentication requests from users and systems simultaneously through connection pooling capability which allows to maintain multiple connections to the database (*Atlassian Documentation*, 2021b) and multi-threading capability allowing each request to be handled by a separate thread (*How Many Threads Does OpenLDAP's Server Process Need?*, 2024), increasing server efficiency, reducing delays and bottlenecks in resource constrained environments.

Weakness & Common Attacks on LDAPS

Improper configuration of certificates or using expired certificates will cause LDAPS connections to fail, causing downtime for the e-commerce platform and connections might be left unencrypted if LDAP was set as a fallback option. This could lead to loss in sales due to connection issues and exposure of customer data over unsecured connection.

LDAPS is susceptible to man-in-the-middle attacks if the certificate verification is not enforced correctly enabling the attackers access to intercept and alter communication between client and the LDAP server, leading to manipulating and exposing confidential customer and employee information.

LDAPS does not provide Multi-Factor Authentication(MFA) by itself, while extensions do exist to allow for MFA support , they often require complex configurations ensuring interoperability between systems, licensing fees for the MFA service by the provider and operational costs to maintain the MFA system (e.g.troubleshooting, support and dedicated IT resources), all of these making MFA integration to LDAPS costly and resource intensive for startup e-commerce (*LDAP MFA and LDAPS MFA | SurePassID*, 2024). Without MFA support and the e-commerce platform solely relying on passwords leads to an increased risk of compromised accounts due to weak, reused and phished passwords.

As LDAP servers were initially designed for directory lookups and as a replacement to the old directory services (e.g. Directory Access Protocol), the servers may struggle to handle authentication requests in high volume environments and on a busy e-commerce platform during peak times (e.g. flash sales) introducing latency and authentication failures. This could impact the e-commerce business' customer experience and result in loss of sales.

LDAP servers are vulnerable to LDAP injections if the website has weak input validation

(Lutkevich, 2022), enabling the attackers to manipulate LDAP queries to gain unauthorized access to privileged and administrator accounts and retrieve sensitive data.

As LDAP servers provide centralized authentication, a failure or compromise in the server could impact the entire e-commerce operation for customers and employees both, rendering them unable to access and log into the accounts, impacting customer trust and revenue during the downtime.

Mitigating Risks in LDAPS for an E-Commerce Platform

Implement automated certificate renewal and enforce strict certificate validation on the website for certificate expiry and management and to prevent Man-in-the-middle attacks to avoid any potential downtime or unsecured connection leading to exposure of sensitive customer and employee data.

Integrate third party Multi-Factor Authentication solutions to protect against unauthorized access to customer and employee accounts with compromised and stolen credentials for the website.

Utilize caching and configure for load balancing across systems to reduce operational overheads on a single system, eliminating authentication delays and avoiding a single point of failure during high traffic periods, preventing website downtime.

Assign roles and groups to employees in the directory based on the organizational structure to restrict access to sensitive information to authorized personnel only.

Enforce strict input validation on the website by checking for length constraints, allowed characters (e.g. rejecting special characters), required format for the input field (e.g. emails and numbers following a specific structure), to prevent against LDAP injection attacks.

Conclusion

While analyzing Kerberos, NTLMv2 and LDAPS as methods for secure authentications, each showcased benefits and limitations suited to different use cases. A combination of these protocols may provide balanced security, scalability and efficiency for a startup e-commerce platform requiring secure customer data, facilitating efficient login for employees and customers and maintaining access controls to sensitive systems.

Integrated Protocol Strategy for Enhanced Security

The business can use Kerberos as its primary authentication protocol as it allows for mutual authentication which would reduce risks like impersonation and replay attacks protecting customer transactions and unauthorized access to sensitive internal systems, supports single sign-on, simplifying user and employee access across the application within the e-commerce platform enhancing customer experience by reducing repetitive logins and increases productivity for employees. Its usage of symmetric key method is computationally less resource intensive compared to asymmetric methods and maintains security making it a suitable choice for businesses with limited resources. Kerberos integrates with enterprise systems like Microsoft's Active Directory, enabling centralized user management, this compatibility also allows for scaling as the business grows.

LDAPS can be used as the supplementary protocol for access control and centralized directory system, allowing the e-commerce platform to securely store and manage user credentials, roles and permissions in the system. This would enable efficient access controls for different user roles (e.g. customers, employees, administrators). As LDAPS also uses TLS encryption by default for securing authentication data, this would ensure compliance with data protection standards such as PCI DSS and GDPR when the platform handles customer

information and payment data. LDAPS being able to be distributed across multiple servers enables load balancing and allows for efficient authentication in high traffic environments during peak shopping periods or sales events ensuring consistent customer experience, preventing downtime and guaranteeing customer satisfaction for the business.

NTLMv2 can be used for legacy systems in the network and as a fallback protocol for systems or environments where Kerberos is not supported, this would be helpful in maintaining flexibility when integrating with vendors that depend on NTLM or when there is a network or configuration issue with Kerberos, providing authentication and ensuring continuity and availability in user access to the system.

This multi protocol strategy aims to provide a balanced approach to security and efficiency while ensuring the diverse needs of the e-commerce platform for securing sensitive data, improving authentication efficiency and providing flexibility for future growth of the business along with meeting compliance requirements, safeguarding customer trust and supporting seamless user experience.

Table 1: Summary of Strengths and Weaknesses of Authentication Protocols

Authentication Method	Strengths and Advantages	Weaknesses and Disadvantages	Mitigating Risks for E-commerce
Kerberos	Mutual Authentication: Verifies both client and server, reducing impersonation risks.	Single Point of Failure: Reliance on the Key Distribution Center (KDC) means that its failure impacts all authentications.	Redundancy: Set up multiple KDCs to prevent system failure and maintain availability. Monitor KDC availability and performance.
	Single Sign-On (SSO): Enables access to multiple services with single login, enhancing usability.	Vulnerable to Replay Attacks: If intercepted, tickets can be reused, particularly before expiry.	Short Ticket Lifetimes & Timestamps: Enforce shorter ticket expiration times; implement network monitoring to detect suspicious access patterns.
	Symmetric Key Cryptography: Less resource-intensive than asymmetric encryption, making it efficient for high-performance needs.	Password-based Attacks: Susceptible to brute-force and dictionary attacks if strong passwords aren't enforced.	Strong Password Policies & MFA: Enforce strong password policies and implement multi-factor authentication (MFA) to strengthen login security.
	System Compatibility: Widely supported in enterprise systems like Active Directory, facilitating centralized access control and scalability.	Time Synchronization Requirement: Requires accurate time sync across systems, or authentication may fail, potentially causing downtime.	Network Time Protocol (NTP): Use a reliable time synchronization service to keep system clocks accurate across the network.
	Widely Supported in Distributed Systems: Used in platforms like Apache Hadoop, PostgreSQL, and other distributed systems for secure authentication	Limited MFA Support: Does not inherently support multi-factor authentication, leaving accounts at risk without third-party MFA integration.	Third-Party MFA Integration: Use third-party MFA tools compatible with Kerberos to add an additional security layer.

Table 1 Continued

Authentication Method	Strengths and Advantages	Weaknesses and Disadvantages	Mitigating Risks for E-commerce
NTLMv2	Built into Windows Systems: No additional licensing or third-party tools needed, providing a low-cost solution.	Vulnerable to Pass-the-Hash Attacks: Attackers can steal hashes and use them to authenticate without needing original passwords.	Credential Guard & Network Segmentation: Enable Windows Defender Credential Guard, restrict network access, and monitor for unauthorized access attempts.
	Improved Security over NTLMv1: NTLMv2 uses HMAC-MD5 for stronger security, protecting against certain brute-force attacks.	Lacks Multi-Factor Authentication (MFA): Only single-factor authentication is supported, making it vulnerable to phishing attacks.	Enhanced Security Policies & Awareness Training: Enforce strict password policies, integrate MFA where feasible, and conduct user training on phishing awareness.
	Session Security Feature: Supports session integrity and confidentiality through encryption of session data, enhancing security during interactions.	Poor Scalability in Large Networks: Not optimized for high-traffic environments, which may lead to performance issues as the network scales.	Limit NTLM Usage & Plan Migration: Restrict NTLM use to legacy systems only; consider migrating to Kerberos or LDAPS for more scalable authentication solutions.
	Fallback for Legacy Systems: Useful for older systems or as a backup when Kerberos isn't available, providing flexibility.	Weak Encryption for Compliance Needs: Encryption uses DES, which may not meet modern standards like PCI DSS, especially for sensitive e-commerce data.	Upgrade to NTLMv2 Session Security: Configure NTLM to use the highest encryption available, such as NTLMv2 session security, to improve data integrity and confidentiality.
LDAPS	Encryption via SSL/TLS: Encrypts communications, including credentials and directory information, ensuring data protection against interception.	Certificate Management Required: Expired or misconfigured certificates can cause downtime and may leave data exposed if connections fall back to plain LDAP.	Automated Certificate Renewal & Monitoring: Use automated certificate renewal services, enforce strict validation, and conduct regular audits of certificate configurations.

Table 1 Continued

Authentication Method	Strengths and Advantages	Weaknesses and Disadvantages	Mitigating Risks for E-commerce
LDAPS	Centralized Directory and Access Control: Simplifies user management across applications, particularly useful for organizing user roles and permissions.	Man-in-the-Middle Risks: If certificate verification is not enforced correctly, connections may be susceptible to interception.	Strict Certificate Validation Policies: Require strict certificate validation and use trusted Certificate Authorities (CAs) to prevent MITM attacks.
	Scalable Structure: Supports hierarchical organization of directory data, caching, load balancing, and multi-server replication for high-traffic periods.	No Built-in Multi-Factor Authentication: MFA integration is possible but complex, potentially costly, and requires additional configuration.	Integrate Third-Party MFA: Add MFA through third-party providers to enhance login security for employees and users, ensuring compatibility with LDAPS.
	Supports Compliance: TLS encryption aids in meeting regulatory standards such as PCI DSS and GDPR, critical for protecting sensitive data.	Susceptible to LDAP Injection: Weak input validation may allow unauthorized access to data through manipulated LDAP queries.	Implement Input Validation Controls: Enforce strict input validation on all LDAP queries to protect against LDAP injection vulnerabilities.
	Open Source Availability: OpenLDAP and other open-source options reduce costs, enabling affordable implementation for start-ups and resource-limited businesses.	Single Point of Failure: A failure or compromise in the LDAP server impacts the entire authentication system, disrupting access for users and employees.	Redundancy & Load Balancing: Distribute LDAP servers across multiple servers with load balancing and failover mechanisms to enhance system reliability and availability.

References

[MS-NLMP]: Session Security Details. (2024, April 23). Microsoft.com. https://learn.microsoft.com/en-us/openspecs/windows_protocols/ms-nlmp/d1c86e81-eb66-47fd-8a6f-970050121347

Apache Hadoop 3.3.6 – Hadoop in Secure Mode. (n.d.). Hadoop.apache.org. https://hadoop.apache.org/docs/stable/hadoop-project-dist/hadoop-common/SecureMode.html

Atlassian Documentation. (2021a). Atlassian.com. https://confluence.atlassian.com/crowd/configuring-caching-for-an-ldap-directory-174227697.html

Atlassian Documentation. (2021b). Atlassian.com. https://confluence.atlassian.com/crowd044/configuring-the-ldap-connection-pool-1085204462.html

Authentication methods. (2013, February 7). PostgreSQL Documentation. https://www.postgresql.org/docs/8.3/auth-methods.html

Authors, R. (2022, November). *LDAP vs. LDAPS: What's the Difference? - Rublon*. Rublon.com. https://rublon.com/blog/ldap-ldaps-difference/

Bhargava, R. (2021, August 11). *What Is LDAP and How Does It Work?* JumpCloud. https://jumpcloud.com/blog/what-is-ldap

Covic, D. (2023, July 17). *Kerberos Overview - Dan Covic - Medium*. Medium. https://medium.com/@dancovic/kerberos-overview-5ac1eb08c721

Deland-Han. (2024, June 5). *VPN connections fail when using the MS-CHAPv2 authentication - Windows Server*. Microsoft.com.

https://learn.microsoft.com/en-us/troubleshoot/windows-server/networking/rras-vpn-connections-fail-ms-chapv2-authentication

Document Library. (2024, September 24). PCI Security Standards Council. https://www.pcisecuritystandards.org/document_library/?hsCtaTracking=885a24d0-8ede-4574-a27b-0a860f17a33a%7Cc910d9ec-4c58-45d2-890a-81c1c8ccbf6f

Drown, D. (2021, February). *Kerberos for Windows, without AD*. https://blog.dan.drown.org/kerberos-for-windows-without-ad/

Garman, J. (2003, August). *Replay Attacks - Kerberos: The Definitive Guide [Book]*. Www.oreilly.com. https://www.oreilly.com/library/view/kerberos-the-definitive/0596004036/ch06s02s02.html

Gates, J. (2024a, March). *LAN Manager authentication level practices*. CalCom. https://www.calcomsoftware.com/the-policy-expert-network-security-lan-manager-authentication-level/

Gates, J. (2024b, March 16). *LDAP Authentication, Configuration and Security Hardening*. CalCom. https://www.calcomsoftware.com/ldap-authentication-and-security-signing-binding-and-configuration/

GDPR. (2016). *General Data Protection Regulation (GDPR)* . General Data Protection Regulation (GDPR). https://gdpr-info.eu

GDPR Compliance Guide for Active Directory. (2024). Artiste1.com. https://artiste1.com/admin/active-directory/gdpr-compliance

Gillis, A. (n.d.). *What is LDAP (Lightweight Directory Access Protocol)?*

SearchMobileComputing. https://www.techtarget.com/searchmobilecomputing/definition/LDAP

Herrmann, B. (2015). *Understanding When to Use LDAP or RADIUS for Centralized Authentication*. https://selinc.com/api/download/110067/

How Many Threads Does OpenLDAP's Server Process Need? (2024). Symas. https://kb.symas.com/performance/threads

Instasafe. (2024, September 2). *LDAP Authentication with Active Directory: How It Works | InstaSafe*. Zero Trust Blog. https://instasafe.com/blog/ldap-authentication-with-active-directory/

Jayaraman, N. (2023, November 7). *What is LDAP- Meaning, Components, Benefits*. Cybersecurity Exchange. https://www.eccouncil.org/cybersecurity-exchange/ethical-hacking/understanding-ldap-guide/

Kressin, J. (2024, May 27). *Understanding Kerberos Part 1: The Basics*. Search-Guard.com; Search Guard. https://search-guard.com/blog/kerberos-elasticsearch-searchguard-pt1/

LDAP MFA and LDAPS MFA | SurePassID. (2024). Surepassid.com. https://surepassid.com/access-control/ldap-mfa-ldaps-mfa

LDAP v3. (n.d.). Docs.oracle.com. https://docs.oracle.com/javase/jndi/tutorial/ldap/models/v3.html

Lenaerts-Bergmans, B. (2024, May). *What is a Pass-the-Hash Attack? | CrowdStrike*. Crowdstrike.com. https://www.crowdstrike.com/en-us/cybersecurity-101/cyberattacks/pass-the-hash-attack/

Lutkevich, B. (2022, May). *What is an LDAP Injection? Definition and How to Prevent*.

Software Quality.
https://www.techtarget.com/searchsoftwarequality/definition/LDAP-injection

Macvittie, L. (n.d.). *Simplifying Single Sign-On with F5 BIG-IP APM and Active Directory* https://www.f5.com/pdf/white-papers/kerberos-apm-wp.pdf

Mahdi Mallaki. (2023, June 25). *NTLM authentication on Linux | Medium*. Medium. https://mallakimahdi.medium.com/ntlm-authentication-on-linux-b8124ec0a0b5

McKeown, E. (2023, May 15). *Top Benefits of single sign-on*. Www.pingidentity.com. https://www.pingidentity.com/en/resources/blog/post/top-benefits-sso.html

Metzler, S. (2020, August 31). *LDAP: Explained*. SecureW2. https://www.securew2.com/blog/ldap-explained

Mora, J. (2024, April). *NTLM vs Kerberos*. TECHCOMMUNITY.MICROSOFT.COM. https://techcommunity.microsoft.com/t5/ask-the-directory-services-team/ntlm-vs-kerberos/ba-p/4120658

NTLM. (2023, March 24). Wikipedia. https://en.wikipedia.org/wiki/NTLM

Palko, M. (2023, October). *The evolution of Windows authentication*. TECHCOMMUNITY.MICROSOFT.COM. https://techcommunity.microsoft.com/t5/windows-it-pro-blog/the-evolution-of-windows-authentication/ba-p/3926848

paolomatarazzo. (2024, June). *How Credential Guard works - Windows Security*. Learn.microsoft.com. https://learn.microsoft.com/en-us/windows/security/identity-protection/credential-guard/how-it-works

Rose, S., Nightingale, J. S., Garfinkel, S., & Chandramouli, R. (2019). Trustworthy email.

Trustworthy Email, *SP 800-177 REV.1*(800-177 REV.1). https://doi.org/10.6028/nist.sp.800-177r1

Single Sign-On (SSO) with LDAP | Harness Developer Hub. (2014). Harness.io. https://developer.harness.io/docs/platform/authentication/single-sign-on-sso-with-ldap/

Using LDAP to Authenticate and Perform RBAC of Management Services. (2024). Oracle.com. https://docs.oracle.com/cd/E27515_01/common/tutorials/general_rbac_ldap.html

Vaideeswaran, N. (2023, April). *NTLM Explained: Definition, Protocols & More | CrowdStrike*. Crowdstrike.com. https://www.crowdstrike.com/en-us/cybersecurity-101/identity-protection/windows-ntlm/

What is lightweight directory access protocol (LDAP) authentication? (2022, June 3). Www.redhat.com. https://www.redhat.com/en/topics/security/what-is-ldap-authentication

Why does Kerberos care what time it is? - IS&T Contributions - Hermes. (n.d.). Kb.mit.edu. https://kb.mit.edu/confluence/pages/viewpage.action?pageId=3908114

WorkOS. (2024). Workos.com. https://workos.com/blog/ldap-vs-active-directory

Xcitium. (n.d.). *NTLM Explained | Understanding NTLM Authentication*. Xcitium. https://www.xcitium.com/ntlm-explained/